

GRC Analyst Portfolio

Comprehensive Governance, Risk & Compliance
Framework
for Fintech/Finance in South
Africa

Prepared by: Ubuntu GRC

June 2025



Portfolio Overview

Comprehensive Ubuntu GRC framework demonstrating practical expertise



Risk Register Development

Comprehensive risk assessment using ISO 27005 methodology for a fictional FinTech startup.
Identified 7 critical risks with detailed treatment strategies and residual risk calculations.

✓ ISO 27005 Methodology Applied



Policy Writing Portfolio

Three comprehensive policy documents aligned with ISO 27001 Annex A controls and POPIA requirements:
Information Security, Data Retention & Destruction, and Access Control policies.

🛡️ ISO 27001 & POPIA Aligned



GRC Dashboard Prototype

Lightweight dashboard design for visualizing compliance status



South African Context

Specifically tailored for the South African regulatory environment

Business Scenario: SecurePay

Fictional FinTech startup demonstrating Ubuntu GRC framework application



SecurePay

Mobile Payment Solutions for South Africa

Company Overview

Newly established FinTech startup based in Cape Town, offering secure mobile payment applications for P2P and C2B transactions. Targeting underserved communities and small businesses with accessible digital payment solutions.

 Mobile P2P payments

 QR code-based C2B payments

 Bank & mobile operator integration

Technology Stack

Cloud-based infrastructure (AWS/Azure), mobile apps for iOS/Android, API integrations with payment gateways, and internal admin portal for operations.

Regulatory Environment

Subject to SARB regulations for payment service providers, POPIA for data protection, and FICA for AML/CTF compliance requirements.

Data Processing

Processes customer information, transaction data, and device information for security and fraud detection.

Risk Register Development

ISO 27005 methodology application and key risk identification

ISO 27005 Methodology

1 Context Establishment

2 Risk Assessment

3 Risk Treatment

4 Risk Acceptance

5 Risk Communication

6 Risk Monitoring & Review

Top Critical Risks

CRITICAL

Unauthorized Database Access (R001)

Weak database access controls and SQL injection vulnerabilities

CRITICAL

Fraudulent Transactions (R004)

Weak transaction monitoring and fraud detection capabilities

CRITICAL

DDoS Service Disruption (R003)

Insufficient DDoS mitigation for critical payment services

Risk Treatment Results

LOW

Policy Writing Portfolio

Comprehensive policies aligned with ISO 27001 and POPIA



Information Security Policy

Foundational document establishing SecurePay's commitment to protecting information assets and providing the framework for implementing security controls.

- ✓ Security objectives & governance
- ✓ Roles & responsibilities
- ✓ 4-theme control framework
- ✓ POPIA alignment

ISO 27001 Annex A Aligned



Data Retention & Destruction

Comprehensive data lifecycle management ensuring compliance with legal requirements while minimizing risks from excessive data retention.

- ✓ Data classification system
- ✓ Retention schedules
- ✓ Secure destruction procedures
- ✓ Regulatory compliance

POPIA & FICA Compliant



Access Control Policy

Framework for managing access to information systems implementing least privilege principles while ensuring business continuity.

- ✓ Least privilege principle
- ✓ Role-based access controls
- ✓ Multi-factor authentication
- ✓ Regular access reviews

Security Best Practices

GRC Dashboard Prototype

Lightweight dashboard for real-time Ubuntu GRC visualization

GRC Dashboard - SecurePay



Overall GRC Status
GREEN

POPIA Compliance
85%

ISO 27001 Controls
78%

Open Incidents
2

Risk Matrix

Likelihood vs Impact Visualization

Key Features

Real-time visualization of GRC metrics with automated scoring and visual indicators.

- ✓ Red/Yellow/Green indicators
- ✓ Risk matrix visualization
- ✓ Compliance progress tracking
- ✓ Incident management metrics

Automation

Minimal manual intervention with automated calculations and dynamic updates.

- ✓ Automated risk scoring
- ✓ Dynamic status indicators
- ✓ Linked data sources
- ✓ Real-time updates

Regulatory Alignment

Comprehensive compliance with international standards and local regulations



ISO 27001:2022

Information Security Management System framework providing structured approach to managing sensitive information and ensuring business continuity.

- ✓ 93 Annex A controls addressed
- ✓ 4-theme control framework
- ✓ Risk-based approach
- ✓ Continuous improvement

Control Coverage



ISO 27005:2022

Information security risk management guidelines providing systematic approach to identifying, assessing, and treating information security risks.

- ✓ Context establishment
- ✓ Risk assessment methodology
- ✓ Treatment strategies
- ✓ Monitoring & review

Risk Management



POPIA

South Africa's Protection of Personal Information Act ensuring lawful processing of personal information and protecting individual privacy rights.

- ✓ 8 processing conditions
- ✓ Data subject rights
- ✓ Information Officer role
- ✓ Security safeguards

POPIA Conditions

Key Achievements

Demonstrating comprehensive Ubuntu GRC expertise for FinTech sector



Comprehensive Risk Assessment

Successfully applied ISO 27001 methodology to identify, assess, and treat 7 critical information security risks specific to the FinTech sector, with all risks reduced to acceptable levels through targeted mitigation strategies



Regulatory Alignment

Developed comprehensive policies that simultaneously address ISO 27001 requirements and POPIA compliance, demonstrating deep understanding of both international standards and South African regulatory landscape

Portfolio Metrics

7

Risks Identified & Treated

3

Comprehensive Policies

93

ISO 27001 Controls Addressed

8

POPIA Conditions Covered

Key Deliverables

 Information Security Risk Register

 Information Security Policy

Recommendations

Strategic roadmap for FinTech Ubuntu GRC implementation in South Africa



Immediate Actions

0-6 months

-  Conduct comprehensive risk assessments using ISO 27005 methodology
-  Implement foundational policies for information security and data protection
-  Establish regular compliance monitoring and reporting processes
-  Invest in employee training and awareness programs

HIGH PRIORITY



Medium-term Initiatives

6-18 months

-  Pursue ISO 27001 certification to demonstrate security commitment
-  Implement automated GRC monitoring tools and dashboards
-  Establish formal incident response and business continuity programs
-  Develop comprehensive vendor risk management processes

MEDIUM PRIORITY



Long-term Strategic Goals

18+ months

-  Integrate GRC considerations into business strategy and decision-making
-  Establish a culture of risk awareness throughout the organization
-  Leverage GRC capabilities as competitive advantages in the market
-  Continuously evolve frameworks to address emerging threats and regulations

STRATEGIC FOCUS

Conclusion & Next Steps

Comprehensive Ubuntu GRC framework ready for implementation in South African FinTech sector



Portfolio Completeness

Delivered comprehensive non-regulatory, policy, documents, and governance prototype
demonstrating practical GRC expertise for FinTech organizations



Industry Impact

Positioned to help FinTech organizations navigate regulatory requirements, build customer trust, and achieve sustainable growth in South Africa.



Regulatory Alignment

Successfully integrated international standards (ISO 27001/27005) with South African regulations (POPIA) for comprehensive compliance coverage.



Future Ready

Framework designed to evolve with changing regulatory landscape and emerging threats in the financial technology sector.